

Adversarial QA & Bug-Hunt Report

University Easy Plans · JO0Dile/MyMenuPack · commits 37f3ffe and 3be9e6e

Brief: actively try to break the application. 16 August 2026

ASSERTIONS RUN	BUGS FOUND	FIXED	CRITICAL LEFT	REJECTED
~1,100 across 15 attack classes	8 6 high · 2 medium	8 each re-proven	0 0 high remaining	10 chased down, not assumed

Every bug below was reproduced against the running application, traced to a root cause, fixed at that cause, then re-run against its exact reproduction and followed by a broad regression. Findings that turned out to be flaws in my own tests are listed too, with the evidence that cleared them.

The 8 bugs

1 Prototype-chain names accepted as grades → NaN GPA

HIGH · web/js/18-gpa.js, web/js/51-gpa-studio.js

Reproduce	Set a completed course's grade to "constructor" (also <code>__proto__</code> , <code>toString</code> , <code>valueOf</code> , <code>hasOwnProperty</code> , <code>isPrototypeOf</code> , <code>propertyIsEnumerable</code> , <code>toLocaleString</code>) and reload.
Symptom	The dashboard and degree audit both showed NaN , and the standing read "Probation" .
Root cause	<code>g</code> in <code>GRADE_POINTS</code> walks the prototype chain, so inherited names passed the guard and <code>GRADE_POINTS[g]</code> returned a <i>function</i> — then multiplied by credit hours. Grades come from <code>localStorage</code> , which an import or a hand edit can write.
Fix	One own-property <code>isRealGrade()</code> helper, exported so GPA Studio stops re-implementing the unsafe check.
Regression	48 hostile grade values re-run → all handled; GPA back to 3.58 on every surface.

2 Same hole in `isNonPassing` / `isFailGrade`

HIGH · web/js/18-gpa.js

Reproduce	Store a grade of "constructor" and inspect course state.
Symptom	The course was reported as failed , holding its dependents locked.
Root cause	<code>!!NON_PASSING[g]</code> is truthy for any inherited name.
Fix	Both now use the same own-property guard.
Regression	Covered by the 48-value grade sweep.

3 `standingFor()` invented **"Probation"** from a non-finite GPA

MEDIUM · web/js/18-gpa.js

Reproduce	Pass NaN to <code>standingFor()</code> .
Symptom	Returned the worst possible label from data that was not a number.
Root cause	NaN fails every comparison, so it fell through the whole ladder.
Fix	A non-finite value now returns "No grades yet" .
Regression	Verified directly; also unreachable now that bug 1 is fixed.

4

getJSON accepted any truthy parse**HIGH** · web/js/14-storage.js

Reproduce	Set <code>aaup_importedPlans</code> to <code>[true,false,null,0,-0,"",{ }]</code> and reload.
Symptom	Uncaught TypeError: Cannot read properties of null (reading 'university') .
Root cause	<code>JSON.parse(raw) fallback</code> only rejected <i>falsey</i> values, so an array, string or number was handed to callers that all expect an object map — becoming <code>plans["1"].university</code> on a null.
Fix	The parsed value must now match the fallback's shape. One chokepoint protecting all 9 call sites.
Regression	405 storage-corruption cases across 15 keys re-run clean.

5

One null plan entry wiped the entire home screen**HIGH** · web/js/28-imported.js

Reproduce	Add <code>plans.__broken = null</code> alongside 25 valid plans.
Symptom	Home rendered 0 cards — one bad sibling cost every plan the student had.
Root cause	The home screen's plan walk read <code>p.university</code> without checking that <code>p</code> is an object, and the throw took the whole grid down.
Fix	Unusable entries are dropped in <code>loadImportedPlans()</code> , where all 55 readers load them.
Regression	17 garbage-entry shapes re-run → 25 cards, no uncaught errors.

6

Prototype-named slugs or non-array prerequisites → zero courses**HIGH** · web/js/02-shared-cross.js, web/js/28-imported.js (×2)

Reproduce	Set a plan's prerequisites to <code>[["__proto__","constructor"]]</code> , or to <code>{nope:true}</code> , or to <code>"prereqs"</code> .
Symptom	The study plan rendered 0 courses .
Root cause	Two traps at once: <code>.forEach/.slice</code> on a non-array threw, and <code>needsMap[b] []</code> returned an inherited <i>function</i> for a slug named <code>constructor</code> , so <code>.push()</code> threw.
Fix	Prerequisite maps are now <code>Object.create(null)</code> , non-string pair members are skipped, and non-arrays are coerced — at all three builders.
Regression	All 21 hostile graphs pass: self-loops, 2/3/12-cycles, a 4000-edge graph, and a fully connected 870-edge graph. Zero wrong unlocks, no hangs.

7

Six modals could not be closed with Escape**MEDIUM** · advisor, roadmap, cloud, shared form overlay, prerequisite graph, story deck

Reproduce	Open each modal and press Escape.
Symptom	Nothing happened. Not a trap — the X and backdrop always worked — but Escape is the expected exit.
Root cause	Each feature wired its own Close button; none owned the keyboard path.
Fix	Escape handlers added, including one for the overlay shared by Settings, the Course Library and several forms.
Regression	All 10 modals now close by Escape, backdrop and X.

A second tab erased the first tab's completed courses

HIGH · web/js/11-module11.js

Reproduce	Two tabs open. Tab A completes 3 courses; tab B then completes 3 different ones; reload.
Symptom	All 3 of tab A's were gone, and only 1 of tab B's survived. Silent data loss, from something as ordinary as keeping the plan in one tab and the dashboard in another.
Root cause	saveProgress() wrote this tab's entire in-memory blob — loaded once at boot — over storage, so the last writer deleted the other's work.
Fix	A save now asserts only what this tab changed: re-read storage, replay our own additions and removals, leave untouched keys alone. Plus a storage listener so a sibling tab's change is adopted and repainted.
Regression	Same reproduction → all 6 completions from both tabs persist (lostA: 0, lostB: 0).

What was attacked, and what held

Attack class	Volume	Result
localStorage corruption	489 cases (15 keys × 27 poisons)	Bug 4. No prototype pollution, no stored XSS, no blank screens.
Garbage plan entries	17 shapes	Bug 5.
Stored XSS / injection	39 payloads × 10 surfaces = 390	0 executions, 0 prototype pollution, 0 event-handler attributes, 0 iframes, 0 javascript: hrefs. Inline-script count identical to a clean load for every payload.
Grade / GPA abuse	48 values, cross-surface	Bugs 1–3.
Prerequisite graphs	21 hostile graphs, run twice	Bug 6. Zero wrong unlocks ; no hangs (all boots ~2.8s) even on cycles and 4000 edges.
Import torture	27 malformed files	None. No data loss, no XSS, no pollution, no foreign keys, no corrupt JSON.
URL / hash abuse	26 hashes + 50 back/forward	None.
Search torture	31 terms	None. Clearing restores all 51 courses.
Modals	10 modals × 3 close paths	Bug 7.
Race / rapid interaction	50-click storm, 208 interleaved, 60 modal opens, 40 plan switches, 120 theme+lang switches, 5 interrupted saves, 30-key spam, 10-step resize	None. Parity holds, DOM matches state, JSON never corrupted.
Multi-tab concurrency	precise disjoint 6-course test	Bug 8.

Attack class	Volume	Result
Fix tool vs broken state	detect → 12× rapid repair → re-detect	None. No execution, no pollution, no corruption; GPA stayed finite.
Admin authorization	4 client-side flag forgeries	None. Dashboard not reachable by setting localStorage flags.
Zoom	6 levels, 50–200%	None.
Stress	2000 courses / 1999 prereq edges	None. 3.3s load, 4.0s open, rAF 5ms, heap 8MB, no freeze.

Rejected — looked like bugs, were not

Each was chased down rather than assumed:

- **39 “inline <script> injected”** — my selector counted the app’s own 3 legitimate inline scripts. The count is identical for a benign payload like “8080” and a hostile one.
- **“5 modals stacked”** — not reachable by a real user: `elementFromPoint` shows the overlay covers the sidebar, so nothing behind it is clickable.
- **“1 modal survived 20 Escapes”** — artifact of firing 20 events in one synchronous burst with no tick. At a realistic 60ms cadence all close (`stuck: []`).
- **“200 interleaved clicks lost a toggle”** — 25 rounds is an *odd* click count, so flipping was correct. Re-run with 26: parity holds.
- **267 “wrongly unlocked” courses** — completed courses also carry `.available`. Excluding them: **zero** wrong unlocks across all 21 graphs.
- **~10 “navigation gone”** storage cases — the app correctly falls back to home with all 25 cards; my heuristic counted sidebar plan-items that do not exist on home.
- **“Course Library rendered zero rows”** — it opens a plan picker first; 57 courses appear after drilling in.
- **“validateMove rejected a legal move”** — the move genuinely was not legal (Calculus II has a dependent that would land before it).
- **Sub-24px tap targets** — decorative legend colour swatches with no click handler.
- **Unlabelled** `.ta-btn` — the hidden toast action button; its label is set when shown.

Not verified — stated, not assumed

- **Cloud Sync, the production admin Worker, and the online AI Worker** — no outbound access from this sandbox (`ERR_TUNNEL_CONNECTION_FAILED`). **Admin authorization was tested only for client-side bypass; server-side enforcement is UNVERIFIED.**
- **Browser zoom** — applied as `CSS body.zoom`, not true browser zoom. Close, but not identical.
- **Real iOS/Android hardware, a real printer, and screen readers** — not tested.
- **Network failure modes** — offline was tested through the service worker, but slow networks, mid-request drops and malformed server responses were not, because the real Workers are unreachable here.

Known non-critical, deliberately unfixed: course-category colour contrast (worst 2.79 vs WCAG AA 4.5). Fixing it is a redesign and would desync the finished video.

Release readiness

Ready to show. CI is at baseline — eslint 0 errors (4 known warnings), stylelint 0 errors (8 known), htmlhint clean, precache OK. Service worker bumped v40 → v42.

The two findings that mattered most were both **silent data loss a real student could hit**: a second browser tab erasing completed courses, and a single corrupt plan entry wiping the entire home screen. Both are fixed and re-proven against their exact reproductions.

All fixes committed and pushed to `claude/claude-capabilities-environments-k88hlo` as `37f3ffe` and `3be9e6e`. No pull request has been opened.